

Report Threat Intelligence & IOC

S9L5 — Analisi Cattura di Rete: Port Scan Detection

Indice

1. Obiettivo

2. Analisi della cattura di rete

3. IOC 1 - TCP Connect Scan: Three-Way Handshake Anomalo & Scansione Porte

4. IOC 2 — Porte Aperte

6. Remediation

Immediato | Contenimento dell'attacco in corso |

Breve Termine | Riduzione della superficie d'attacco |

Lungo Termine — Prevenzione di attacchi futuri

7. Conclusioni

1. Obiettivo

L'esercitazione di oggi, consiste nell'analisi di una cattura di rete effettuata con Wireshark, data come come allegato. L'obiettivo dello stesso è di analizzare la cattura e rispondere ai seguenti quesiti:

- Identificare ed analizzare eventuali **IOC**, quindi l'evidenze di **attacchi in corso**;
- Se durante l'analisi sono stati trovati **IOC**, fare delle ipotesi sui potenziali vettori di attacco utilizzati;
- Consigliare delle Remedation per ridurre gli impatti sia dell'eventuale attacco che in un eventuale attacco futuro.

2. Analisi della cattura di rete

L'analisi della cattura di rete, ha rilevato evidenze chiarissime di una scansione **TCP Connect Scan** condotta dall'host **192.168.200.100** nei confronti del target **192.168.200.150**.

La prima evidenza è la macchina target **Metasploitable 2** con il suo indirizzo IP **192.168.200.150**.

La scansione ha prodotto **2.083 pacchetti** in circa 37 secondi.

La seconda evidenza, data la molteplicità delle richieste TCP, è il tipo di attacco utilizzato, ovvero un **nmap**, lanciato ovviamente dall'host a Meta, restringendo così il campo, degli attacchi usati.

Siccome con **nmap** si possono lanciare diversi tipi di attacchi, ho dovuto approfondire l'analisi della cattura di rete, che ha portato a identificare sia il comando lanciato che le porte aperte.

3. IOC 1 - TCP Connect Scan: Three-Way Handshake Anomalo & Scansione Porte

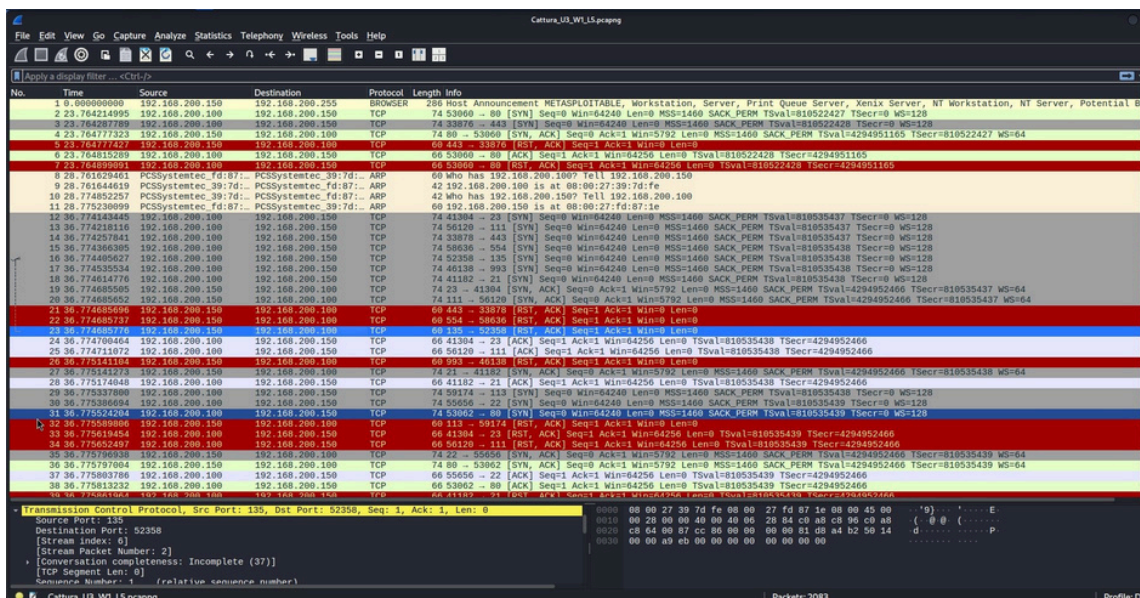
L'IOC principale identificato è il pattern sistematico di connessioni TCP: ogni porta viene sondata con un three-way handshake completo (**SYN** → **SYN-ACK** → **ACK**) immediatamente seguito da un **RST-ACK** per chiudere la connessione senza trasmettere dati applicativi. Questo comportamento è la firma caratteristica del TCP Connect Scan di nmap (-sT): a differenza dello **stealth SYN scan**, completa ogni handshake ma non stabilisce mai una connessione applicativa reale.

Tramite quest'analisi sono riuscito a risalire ad una parte del comando che l'attaccante ha usato, ovvero:

- **nmap -sT 192.168.200.150**

Questa teoria viene anche avvalorata dall'Arp Request lanciata, dalla riga 8 all'11, perché quando **nmap** deve scansionare un host sulla stessa subnet locale, prima di mandare qualsiasi SYN deve conoscere il **MAC address** del target per costruire il frame Ethernet. Quindi automaticamente manda un:

- **ARP Request: "Who has 192.168.200.150? Tell 192.168.200.100"**



La seconda analisi è stata quella di capire se sono state effettuate scansioni alle porte, e nel caso quante porte sono state scansionate, applicando su wireshark dei filtri:

- `tcp.flags.syn==1 && tcp.flags.ack==1 && ip.src==192.168.200.150`

Grazie a questi filtri emergono **1.039 pacchetti**, diretti a porte alte in rapida sequenza. Questo pattern indica che la scansione ha coperto parallelamente porte basse e alte, con un **burst rate di 19.75 pkt/ms** intorno a `t=36.775s`, questa velocità conferma l'utilizzo di uno strumento automatizzato, velocità impossibile da raggiungere manualmente.

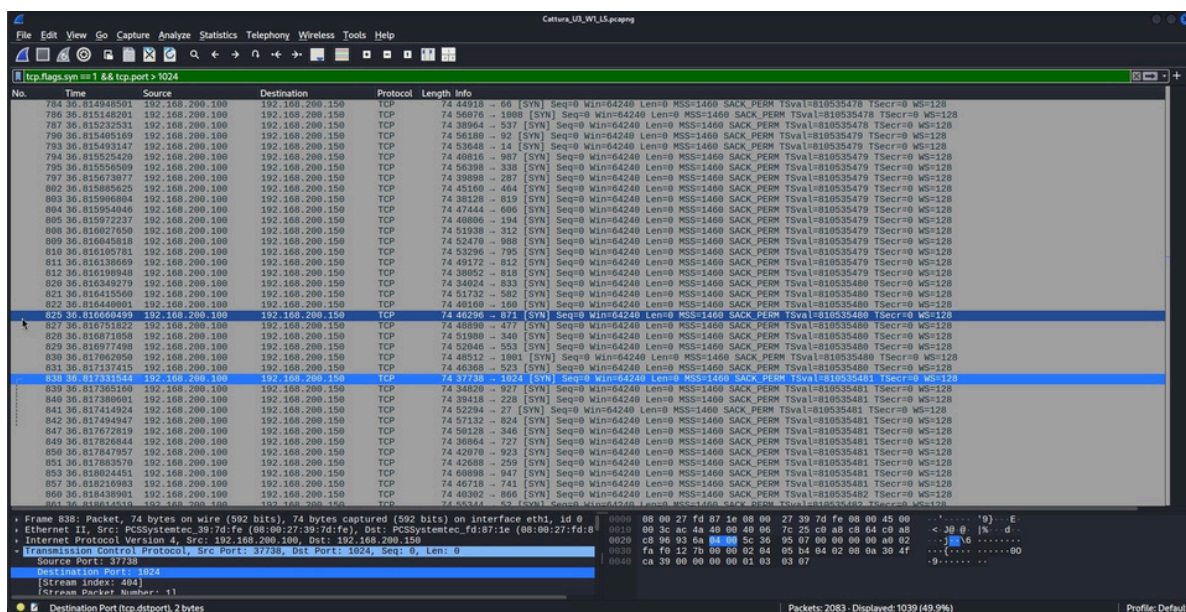
Avendo l'evidenza della scansione delle porte, lanciato dalla macchina target, è stato naturale procedere indagare ed evidenziare quante porte sono state scansionate, per comprendere meglio e ricostruire il comando lanciato; se una scansione completa delle porte (si evince subito che non è stata effettuata una scansione completa per il quantitativo dei pacchetti che ci sono all'interno della cattura di rete, troppo pochi per un'analisi completa), una scansione delle **top ports**, oppure una scansione con un range stabilito.

Per effettuare quest'analisi, ho applicato il seguente per evidenziare quali porte son state scansionate:

- `tcp.flags.syn==1 && tcp.flags.ack==0 && tcp.port > 1024`

Grazie a questo filtro, son riuscito a evidenziare le porte scansionate procedendo ad effettuare un'analisi manuale, evidenziando che è stata effettuata una scansione ad un **range di porte specifico**, ovvero dalla **porta 1 alla 1024**, completando e risalendo così all'intero comando lanciato dall'attaccante, ovvero

- `nmap -sT -p 1-1024 192.168.200.150`



4. IOC 2 — Porte Aperte

Dopo aver individuato la tipologia d'attacco alla macchina target, la scelta più ovvia e immediata è stata quella di andare ad evidenziare quali porte fossero aperte, e quanto la loro apertura fosse gravi a livello di sicurezza; per effettuare questa indagine ho applicato il seguente filtro:

- `tcp.flags.syn==1 && tcp.flags.ack==1`

mostrando esclusivamente i **12 pacchetti di risposta positiva** dal target.

Questi SYN-ACK confermano i servizi in ascolto e rappresentano la superficie d'attacco reale del sistema.

La **porta 80** appare con doppia risposta per un test isolato a `t=23.7s`, eseguito prima della scansione completa.

No.	Time	Source	Destination	Protocol	Length	Info
4	23.764777323	192.168.200.150	192.168.200.100	TCP	74	80 → 53060 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294951105 TSecr=810522427 WS=64
19	36.774685505	192.168.200.150	192.168.200.100	TCP	74	23 → 41304 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535437 WS=64
20	36.774685502	192.168.200.150	192.168.200.100	TCP	74	111 → 56128 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535437 WS=64
27	36.775141273	192.168.200.150	192.168.200.100	TCP	74	21 → 41182 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535438 WS=64
35	36.775795938	192.168.200.150	192.168.200.100	TCP	74	22 → 55556 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535439 WS=64
36	36.775797004	192.168.200.150	192.168.200.100	TCP	74	80 → 53062 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535439 WS=64
57	36.776904828	192.168.200.150	192.168.200.100	TCP	74	445 → 33842 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535440 WS=64
59	36.776904961	192.168.200.150	192.168.200.100	TCP	74	139 → 46990 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535440 WS=64
61	36.776905843	192.168.200.150	192.168.200.100	TCP	74	25 → 60632 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535440 WS=64
63	36.776905123	192.168.200.150	192.168.200.100	TCP	74	53 → 37282 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535440 WS=64
164	36.781487210	192.168.200.150	192.168.200.100	TCP	74	512 → 45648 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535445 WS=64
267	36.788905940	192.168.200.150	192.168.200.100	TCP	74	514 → 51396 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952467 TSecr=810535452 WS=64
984	36.825722553	192.168.200.150	192.168.200.100	TCP	74	512 → 42840 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952471 TSecr=810535489 WS=64

5. Porte Aperte e le Superfici d'Attacco

Le **12 porte identificate** dai SYN-ACK del target coprono servizi criticamente vulnerabili. Metasploitable 2 è una macchina deliberatamente insicura, ma in un ambiente di produzione la presenza di questi servizi costituirebbe un rischio immediato.

Le **porte identificate** sono qui elencate con anche il loro livello di rischio:

- **21 (FTP) RISCHIO: Critico**
- **22 (SSH) RISCHIO: Alto**
- **23 (Telnet) RISCHIO: Critico**
- **25 (SMTP) RISCHIO: Medio**
- **53 (DNS BIND) RISCHIO: Alto**
- **80 (HTTP) RISCHIO: Alto**
- **111 (portmapper) RISCHIO: Medio**
- **139 | 445 (NetBIOS | Samba) RISCHIO: Critico**
- **rexec, rlogin, rsh (porte dedicate ai servizi “r”) RISCHIO: Critico**

6. Remediation

Immediato | Contenimento dell'attacco in corso |

Isolare il target	Disabilitare la porta switch o applicare VLAN isolation su 192.168.200.150
Bloccare l'IP	ACL firewall per bloccare 192.168.200.100 immediatamente
Monitorare porta 6200	Traffico verso 6200/TCP = exploit vsftpd backdoor già attivo
Analizzare i log	Verificare connessioni post-scan già avvenute sui log di sistema

Breve Termine | Riduzione della superficie d'attacco |

Disabilitare r-commands	sudo update-inetd --disable exec,login,shell
Disabilitare Telnet	sostituire con SSH a chiave pubblica
Rimuovere vsftpd	Sostituzione con ProFTPD
Bloccare porta 445/SMB	Se non utilizzato, rimuovere il protocollo SMB

IDS/IPS	Snort/Suricata, regola per N SYN verso porte diverse nello stesso secondo dallo stesso IP
Port knocking	Single Packet Authorization per i servizi di amministrazione remota
Minimo privilegio	Esporre solo i servizi strettamente necessari, attack surface minimization
Vulnerability scan	nmap + NSE scripts periodici per rilevare nuove esposizioni
SIEM	Logging centralizzato per correlare eventi di scan con tentativi di exploit

7. Conclusioni

La cattura di rete contiene evidenze inequivocabili di un TCP Connect Scan condotto dall'host 192.168.200.100 verso il target 192.168.200.150 (**Metasploitable 2**)

L'IOC primario è il pattern sistematico **SYN** → **SYN-ACK** → **ACK** → **RST** su 1.024 porte consecutive in meno di 40 secondi, con un burst rate di 19.75 pkt/ms. Sono state identificate 12 porte aperte, di cui 6 classificate CRITICO, con la presenza di **vsftpd 2.3.4** (*backdoor CVE-2011-2523*), r-commands senza autenticazione e Telnet in chiaro. In un ambiente di produzione, la scoperta di questo traffico richiederebbe un'azione di contenimento immediata, avendo un'esposizioni gravissime